

Eng 5.4. Cyber Crisis Management

Task 1 - Introduction

Crisis Management Team (CMT) whose job is specifically to navigate us through these troubled waters!

Task 2 - What is a Cyber Crisis

What is a Cyber Crisis?

The SOC receives log information that creates events and alerts. In the case that an alert is sufficiently serious, a cyber incident occurs. However, based on the severity of the incident, the blue team decides the best response. In our example, only a level 4 incident would trigger the **Crisis Management Team (CMT)**. As a refresher, these were the four levels:

- **Level 1: SOC Incident** - Small enough that the incident can be taken care of directly by the security operations centre (SOC), such as a user reporting a phishing email
- **Level 2: CERT Incident** - Small enough that a team in the SOC can take care of the incident, such as a single user that has interacted with a phishing email
- **Level 3: CSIRT Incident** - A larger incident that requires not just the SOC team, but also incident managers, such as multiple users that have interacted with a phishing email that contains malware
- **Level 4: CMT Incident** - A critical incident where the CSIRT requires the ability to invoke nuclear actions, such as an incident where ransomware is being deployed and the CSIRT needs to take the environment offline to protect the rest of the estate

So, how does the team actually decide the level of an incident? This is done through an incident severity classification matrix as shown below:

		Affected Users		
		High-System Wide Business unit, Department, Location	Medium-Multiple Users Number of Users	Low-Single User Single User
Impact	High Can no longer perform primary work functions	Critical	High	Moderate
	Medium Work Functions impaired, the workaround in place	High	Moderate	Low
	Low Inconvenient	Moderate	Low	Low

While this is an example, most incident severity classification methods rely on measuring the scope of the incident against the number of systems or users that are impacted vs the difficulty of recovering the affected systems and assets. Therefore, if many users are affected on a critical system, this would usually result in the incident being rated critical, resulting in the CMT getting involved. Some organisations also add certain special rules to their severity matrix. For example, if any amount of customers are affected, the incident severity is rated as critical.

Answer the questions below

What would the severity rating of an incident be where multiple users are affected and the impact is medium?

Moderate

What would the severity rating of an incident be where multiple users are affected and the impact is low?

Low

What would the severity rating of an incident be where an entire business unit is affected and the impact is high?

Critical

Task 3 - The Roles and Responsibilities in a CMT

Not all Voices are Equal: There are several roles and responsibilities that have to be taken care of in the CMT. Normally, not all CMT members are involved from the start. Depending on the crisis, members are added as needed. This is to help ensure that the CMT can respond as rapidly as possible.

While in most cases a democracy is the best solution to ensure that everyone's voices are heard, the opposite is true for CMT. An autocracy is the best approach for a CMT to ensure that actions are taken decisively without wasting precious time. Usually, this responsibility would fall on the CEO. This is a fairly extreme approach and to share the responsibility of making these decisions, some CMTs will provide voting rights to key individuals, usually no more than five. So while it is still a small team that can request that actions are taken, the responsibility no longer lies on just one individual.

Roles in the CMT: The table below details some of the roles and responsibilities you can find in a typical CMT:

Role/Responsibility	Description
CMT Chair	The Chair is the person that leads the CMT. Usually, this role is fulfilled by either the CEO or the COO of an organisation. The Chair is responsible for leading the CMT and, as mentioned before, is usually responsible for having the final say in what actions will be implemented during the cyber crisis.
Executives	Executives are usually part of the CMT. This includes the CEO, COO, CIO, CTO, CFO, and even the CISO. In cases where not just the CEO is responsible for decision-making, these executives would each be granted a voting right. As executives will ultimately be held accountable for what happened during the incident, they are involved in the CMT to ensure that the damage is kept as small as possible.
Communication	An important responsibility in the CMT is communication. This includes communications that are being sent both internally to employees and externally to customers. An important part of any CMT is staying in control of the narrative to help ensure that unnecessary panic is not created. Therefore, communication during the cyber crisis is incredibly vital.

Legal	While we would like to believe that the CMT can take any action, it is important to ensure that these actions are actually legal. A very common discussion during certain cyber crisis scenarios is whether a ransom will be paid or whether the team will interact with the threat actors. It is important to note that in certain countries, these actions may not even be legal for the team to do.
Operations	One of the CMT member's sole responsibility is to concern themselves with the best possible approach to ensure that the operations of the organisation are affected the least amount possible during the cyber crisis. In certain cases, this role is fulfilled by the COO; however, it can also be fulfilled by an entire team of experts that are looking for ways that business can continue during the crisis.
Subject Matter Experts	Most of the members of the CMT are not technical. These are members that are exceptional at business concerns but do not usually concern themselves with the day-to-day complexities of actually running the organisation's systems. During a cyber crisis, subject matter experts (SMEs) play a vital role in providing critical information to the members of the CMT. This information then helps inform the team about the crisis scope and which actions would be the best to perform. During a cyber crisis, this would most likely include the head of the SOC and/or the incident manager of the CSIRT.
Scribe	Note-taking is incredibly important during a cyber crisis. It is important to create a full timeline of events as this often has to be disclosed to other third parties, such as the government or regulator. The role of the scribe is therefore important to detail all events and conversations during the CMT session.

Answer the questions below

Who is responsible for note-taking in the CMT?

Scribe

Who is responsible for leading the CMT session?

Chair

Who is responsible for ensuring that the actions taken by the CMT do not break the law?

Legal

Who is responsible for making sure that the stakeholders are informed during the CMT?

Communication

Who is responsible for providing more technical information to the CMT to ensure that they can take the appropriate actions?

Subject Matter Experts

Task 4 - The Golden Hour

When the CMT is invoked, the first hour is one of the most crucial. Similar to any investigation, as more time progresses, rebuilding what has happened and recovering from it becomes harder. We refer to this as the Golden Hour. During the Golden Hour, the CMT has to perform several critical steps.

Assembly: The first step in the Golden Hour is to assemble the CMT. Once the CSIRT decides to invoke CMT, a process should be followed to notify all initial CMT members that they are required to help with a cyber crisis. Usually, a playbook and call tree are created for this. It is incredibly important since some of the required members may not be available (for example, the COO could be stuck on an overnight flight). Therefore, their replacement and their replacement's replacement should already be documented.

Usually, the CSIRT Chair would be responsible for invoking the CMT and then performing the initial notification. From there, several members can assist in assembling the CMT. The team should also decide if the team would assemble remotely or in person and what communication channels will be used. While this decision might sound simple, it is often harder than you would think. It could be that the CSIRT has a strong suspicion that their primary communication channels have been compromised by the threat actor and therefore, out-of-band communication will be required.

Information Gathering: Once the CMT has been established, the very first step is to understand what has happened and what actions should be taken immediately.

For a cyber crisis, this is usually done in the form of a CSIRT briefing where the CSIRT provides:

- A summary of the information discovered up to this point
- A summary of the actions that have already been taken by the team and the effect they had on the incident
- Recommendations as to what nuclear actions should be taken immediately by the CMT

Crisis Triage: Once the CMT has been briefed, it is important for the team to triage the incident and consider the actions proposed by the CSIRT. The CMT should think carefully about the impact that the actions would have on the organisation and already think about what steps can be taken to limit the impact. During this triage phase, the team will also decide on which other stakeholders should be involved in the CMT.

Notifications: As mentioned before, controlling the narrative is incredibly important. As such, one of the first steps that the CMT should already perform during the Golden Hour is to prepare and in certain cases send out communication, both internally and externally. Usually, CMTs would prepare by making use of holding statements. These are messages that do not divulge exactly what is happening, but provide reassurance that the team is investigating and will provide more feedback as information becomes available. This can help calm the situation as stakeholders are aware that the team is busy working on whatever the issue is.

Answer the questions below

| What is the first step that has to be performed during the CMT golden hour?

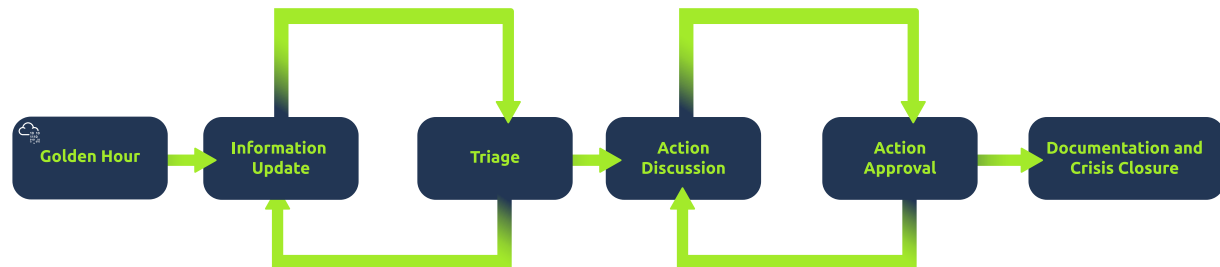
Assembly

| In the event of a cyber crisis, who provides the update to the CMT?

CSIRT

Task 5 - The CMT Process

Once the CMT has been established and the Golden Hour actions have been performed, the CMT starts with a cyclic process to deal with the crisis, as shown below.



It is important to note that during the entire process, the CMT remains static. Rather than have members of the main CMT split off and find information, SMEs are used to bring information to the CMT. This is because if the CMT team were to split off during a critical moment, it would waste time to assemble the team again. This model ensures that the CMT can always receive critical information from stakeholders and SMEs.

Information Updates: The CMT receives updates from the various stakeholders. This usually happens in the form of briefings with SMEs. The goal is to provide the CMT with new information to better understand the scope of the crisis and what impact actions taken in the past have had on the crisis. The CMT decides how often these update sessions are performed. At the start of the crisis, these updates would often be more frequent.

As mentioned before, the CMT usually consists of members that are not as technical. It is, therefore, important that SMEs provide the update information in a manner that can be understood by the CMT. Usually, technical information is abstracted in the update and the focus is more on the impact of what has happened than what has actually happened.

Triage: Once the team receives new information, the triage process has to occur again. During this phase, the CMT decides if the severity of the crises should be raised or lowered and if any new SMEs should be involved in the CMT. The CMT also needs to decide if there will be any new communication sent out internally and externally.

Action Discussions: Using the new information provided by the various SMEs, the CMT has to discuss the proposed actions. The goal of these discussions is to understand the impact that these actions would have on the organisation. In this case, we are no longer talking about easy and small actions, such as removing a phishing mail from a user's mailbox. We are talking about large actions such as:

- Restricting remote access to the environment by halting all VPN access
- Performing a domain takeback of the Active Directory domain
- Switching a system over to the disaster recovery environment

These are actions that the CMT can't take lightly, as they would impact the business. The goal of discussions is to better understand that impact and allow the team to determine if there may be any less impactful, but still effective actions that can be taken.

Action Approvals: The CMT chair will usually limit the amount of time for discussions. This is to ensure that the discussions do not go on forever, leading to inaction. Furthermore, depending on the scenario, the situation may worsen with more time. For example, if ransomware is being deployed from a central location such as Group Policy Objects, the entire Windows environment would be encrypted within 120 minutes! Every single minute the team discusses actions longer, the ransomware is spreading. Therefore, these discussions are limited before the team decides which actions will be followed.

As discussed before, this is usually not done in a very democratic way and will often be a decision made directly by the CEO. These decisions are not made lightly, as the executives will ultimately be held accountable for the crisis; however inaction can often be much more detrimental. Would you be able to make these critical decisions, choosing between the lesser of two evils in a limited amount of time?

Documentation and Crisis Closure: Once the crisis has been remedied, it has to be documented. Using the notes from the scribe, a crisis document is created. This document details what happened during the crisis and what actions were implemented to deal with the crisis. This information is not just for the archive, but can be used by the CMT to learn lessons about the crisis and adapt their processes and policies to better deal with a cyber crisis in the future.

Answer the questions below

What is the term used to describe the process by which the CMT determines the severity of the crisis?

Triage

Who is ultimately responsible for ensuring that the CMT takes action?

CMT Chair

Who will ultimately be held accountable for the crisis?

CEO

Task 6 - The Importance of SMEs

Jack of All Trades: The members of the CMT usually have broad scopes for their roles. For example, the CEO is responsible for running the entire organisation. While the CEO might have extensive knowledge of several things in the organisation, it cannot be expected that they are an expert in everything that the organisation does. This is the case for most of the CMT members. As such, this team in isolation would not be able to deal with the crisis and therefore, have to leverage the expertise of others around them.

The Masters of One: This is where subject matter experts come into play. As a security engineer, you may be involved in a CMT if the crisis pertains to your specific division. As the security engineer, you should have an incredible depth of knowledge of your specific system or asset and can therefore provide vital information to the CMT.

The CMT can only take effective actions if the following is true:

- The CMT must have an accurate understanding of the scope of the incident, including what has happened and what the impact is on the business. It will never be possible to understand the full crisis scope as the investigation will still be ongoing, but having an as clear as possible picture is important.
- The CMT has to understand what actions are available for them to take and what the impact vs effectiveness of these actions would be.

SMEs play a critical role in providing this information. As a security engineer, you will understand the system best to know what potential actions can be taken to

recover from the crisis. You will know how long backups are kept. You will know whether the environment can switch to DR. You will know what the impact would be if you have to take critical assets in the environment offline.

This information must be clearly communicated to the CMT to ensure they can make an informed decision. Without SMEs, it would be impossible to recover from a crisis.

Answer the questions below

Who is responsible for providing the CMT with technical and in-depth information to allow them to make an informed decision during the crisis?

Subject Matter Experts

Task 7 - The Actions Available to the CMT

Apart from the technical response the CMT can take to deal with the crisis, there are other actions that the team needs to consider and potentially take. Some actions will help the team control the narrative, while others may be required by law.

Internal Communication: The CMT will have to decide what communication will be sent internally. This doesn't just include messages that will go to employees, but also communication that is prepared for key divisions such as the help desk. Depending on the technical response taken by the CMT, the help desk might receive an influx of support queries. To ensure that the help desk can assist employees and to limit the spread of panic, the CMT will also prepare communication for this team. While the team can create this communication during the crisis, it is often not recommended as limited time is available which could lead to mistakes. Rather, the team should have already prepared holding statements that can simply be tweaked before being distributed.

External Communication: External communication is just as important. Again, this does not just cover the communication that is sent directly to customers, but also communication such as comments to the press or interviews that will be performed. This component has become vital and incredibly difficult to navigate in today's time due to social media. Often, organisations will employ teams that will specifically take care of this communication during an incident to help ensure that

the public is informed about what is happening without spreading fear and panic, which could cause reputational damage to the organisation.

Informing the Regulator: Depending on the category of the organisation, there may be the need to inform other third parties. For example, in the financial sector, organisations are usually required by law to notify their respective regulator if there is a crisis. This is because the crisis could have an impact on the entire country. Another common regulator that must be informed during a crisis is the information regulator if the crisis has resulted in the breach of customer information in countries that have to adhere to laws such as GDPR.

Contacting Law Enforcement: Also, depending on the country of the organisation, there may be a need to contact law enforcement agencies, for example, the FBI. Usually, these processes are defined by the CMT before a crisis and will be part of their playbooks. Law enforcement agencies can often help with the investigation and help to ensure that the chain of custody of forensic evidence is followed to help with prosecution later.

Exercising CMT: Now that you understand the CMT process, it is time to use that knowledge to deal with a cyber crisis. Launch the static site and take care of the crisis!

Answer the questions below

What is the value of the flag you receive after successfully dealing with the cyber crisis?

THM{The.Crisis.has.been.managed!}

Task 8 - Conclusion

In this room, we have learned about how a crisis management team deals with a cyber crisis. To summarise:

- When the severity of an incident becomes sufficiently large, the CSIRT will invoke CMT to help them deal with the crisis.
- The CMT has to make the most of the Golden Hour to ensure that crucial time is not lost to deal with the crisis.

- The CMT follows a process of receiving updates on the crisis scope and discussing the crisis before taking action to help close the crisis.
- Subject Matter Experts play an important role in providing critical information to the CMT to help them better understand the scope of the crisis and take the appropriate actions to deal with it.